

AWS-EnvBuilder

AI Implementation Contract and Prerequisite Failure-Routing Guide

AUDIENCE	ChatGPT, coding agents, CI assistants, automation designers, and human reviewers supervising them
BASELINE	Version 1.0; repository feature baseline 341f6fe, merged into main by 3aa0242
PURPOSE	Safe, repeatable, and reviewable AWS test/development environments

Prepared from the reviewed AWS-EnvBuilder repository. No AWS resource is created by reading this document.
Repository: <https://github.com/cbieger/AWS-EnvBuilder>

Contents and reading path

Read the sections in order for a first deployment. Returning operators can use the quick-reference and failure sections directly.

- 1 Role, authority, and normative language
- 2 System boundaries and protected assets
- 3 Required phase order
- 4 Integration and application contract
- 5 Universal failure-redirection protocol
- 6 Prerequisite gate routing matrix
- 7 Creation implementation procedure
- 8 Scheduled teardown implementation
- 9 Manual destruction implementation
- 10 Logging, retention, secrets, and evidence
- 11 Validation and acceptance criteria
- 12 Operator response templates
- 13 Machine-readable execution contract
- 14 Repository map and official references

CAUTION: A command is not permission

Examples show syntax. They do not replace account-owner approval, a reviewed Terraform plan, the exact runtime confirmation, or your organization's change process.

1. Role, authority, and normative language

STOP: Primary directive

Implement AWS-EnvBuilder as a cautious, review-first companion inside an existing application repository. Preserve the repository's safety gates. Never infer authorization for an AWS write, destructive action, credential creation, cost acceptance, Git commit/push, or bypass flag from the fact that a command exists.

Normative terms

Term	Meaning
MUST / MUST NOT	Hard requirement. Failure blocks the dependent phase.
SHOULD / SHOULD NOT	Strong default. Deviation requires a documented reason and human approval.
MAY	Optional action within already authorized scope.
FAIL CLOSED	Stop without changing AWS when identity, ownership, permissions, state, timing, cost, or deletion scope cannot be proved.
REDIRECT	Give the operator a specific correction path, safe verification command, and exact retry point. Never merely say try again.

Agent authority rules

- Read-only inspection, local validation, cost display, application scanning, plan creation, status, logs, and review-only inventory are allowed only when the operator has put the relevant repository/account in scope.
- AWS writes require the script's exact interactive confirmation and the human's explicit approval. Do not synthesize, prefill, or hide the phrase.
- Deletion requires a separately reviewed destroy plan and exact confirmation. Full self-destruct requires review-only first, a pause for independent approval, then a new execute invocation.
- Never request that the operator paste an AWS access key, secret, session token, MFA code, phone number, email address, tfstate, or secret-bearing log into chat. Direct them to approved local/browser profile flows.
- Do not commit, push, open a PR, or merge unless explicitly requested. Before a requested commit, show the proposed file list and commit message for review. Preserve unrelated local changes.
- Do not translate AWS root into sudo/OS root. Do not suggest --run-as-root to get around a normal root refusal; it is an explicit one-invocation owner exception only.

2. System boundaries and protected assets

Managed runtime

- Terraform owns VPC/subnets/route, ALB, Auto Scaling/launch template/EC2 runtime, security, instance roles, ECR, runtime logs, ALB logs, account-wide budget definitions, and optional scheduled-control resources.
- Instances are replaceable and local disks are non-durable. Application data stores are out of scope unless a separately reviewed module is added.

Protected bootstrap assets

- The separately bootstrapped versioned S3 backend and its object history survive routine and scheduled destroy.
- The first-run service IAM user/profile survives routine and scheduled destroy.
- Full self-destruct may delete them only under explicit flags and exact ownership/credential/account proofs after runtime state is empty.

Sensitive local and state material

Artifact	Policy
.workspace/	Ignored local profile marker, generated schedule artifacts, and transient data. Never package or commit.
terraform/backend.hcl	Ignored environment-specific backend coordinates. Never copy casually between projects.
terraform/terraform.tfvars	Ignored real settings. Review locally; never assume example values are approved.
*.tfstate / plans / .terraform	Never commit/package. State may expose sensitive scheduled contact inputs.
application.auto.tfvars.json	Ignored immutable ECR digest output; regenerate through publish_app.
scheduled_destroy.auto.tfvars.json	Mode 0600 contact/deadline configuration; never commit/package/log.
logs/	Success/error evidence with defined rotation; never quote secrets or PII to the model.

CAUTION: Inventory is not deletion authority

AWS has no universal account/Region asset-list API. The self-destruct census is broader than its deletion scope. Unrelated, untagged, unsupported, ambiguous, other-account, or other-Region assets are report-only and **MUST NOT** be auto-deleted.

3. Required phase order



Phase	Permitted work	Exit evidence
A. Discover	Read AGENTS/instructions, Git status, repository docs, app manifests, Docker contract, and existing infrastructure. No writes.	Correct repository/path and no collision with user changes.
B. Local validate	Run workspace validate and inspect package contents. Resolve syntax/tests/providers/tooling.	Exit 0; retained log; no AWS write.
C. App qualify	Run inspect_app on absolute parent application path; human source/Docker review.	No blocking findings; port/health/state/log decisions recorded.
D. First identity	Verified AWS root performs one-time service bootstrap; root session ends; service identity passes strict preflight.	Exact account and service-user ARN; no root for normal work.
E. Configure	Create ignored tfvars; guarded backend bootstrap; confirm budget/cost/network/retention inputs.	Owned backend.hcl and approved settings.
F. Plan	Strict preflight, channel validation if selected, Terraform saved proposal.	Fresh reviewed plan with only intended actions.
G. Apply	Exact cost approval; upload reviewed schedule source if enabled; apply exact plan.	Status healthy; budget/SNS confirmations assigned.
H. Publish	Inspect, exact build approval, push, capture digest; plan/apply refresh.	Digest deployment healthy and observable.
I. Operate	Status/log/schedule reads; fresh plans for change; log rotation; cost response.	Named owner and destroy deadline.
J. Destroy	Routine, scheduled, or full-review/execute path selected by scope.	Runtime gone; retained assets documented; Billing follow-up assigned.

STOP: No phase skipping

A later passing command does not erase an earlier failed gate. Resume at the failed gate, regenerate downstream plans/artifacts, and repeat approvals when inputs or time-sensitive data changed.

4. Integration and application contract

Repository attachment algorithm

1. At the builder source, run local validate. If it fails, route to G03/G04 and do not package.
2. Run scripts/package.sh with an approved version label. Verify the SHA-256 checksum and archive listing.
3. Extract into destination/infrastructure/aws-envbuilder on a review branch. Never extract over an edited copy.
4. Confirm excluded classes remain absent: .git, sources, handoffs, credentials, .workspace, .terraform, state, plans, backend.hcl, real tfvars, generated contact/application variables, logs, inventory JSON, dist.
5. Review destination Git diff. Preserve unrelated user changes. Do not stage or commit without explicit permission and prior note/message review.
6. Run local validate again from the attached folder. Record builder release/checksum/commit in the destination change notes.

Application acceptance contract

ID	MUST prove	Block when
APP-01	Readable Dockerfile and .dockerignore excluding .git and .env*.	Missing/unreadable or unsafe exclusions.
APP-02	Pinned/versioned base, manifests, and lock files needed by build.	Floating/unreviewed provenance or unresolved dependency install.
APP-03	Process listens on 0.0.0.0:container_port.	Loopback-only or port mismatch.
APP-04	Fast unauthenticated health route returns 200-399.	Auth, redirect loop, slow/dependent health, or non-success.
APP-05	Durable records/uploads/sessions are external or intentionally disposable.	Local disk is the only copy.
APP-06	Useful stdout/stderr without secret/PII content.	Sensitive logging or no diagnosable errors.
APP-07	Tolerates replacement, retry, and brief old/new overlap.	Single-host assumptions or unsafe migrations.
APP-08	No private key/AWS credential-shaped material enters Docker context.	Scanner or manual review finds possible secret.

```
./scripts/inspect_app.sh /absolute/path/to/application --json
```

Use JSON output for programmatic evaluation, but do not treat it as a complete code/security review. An AI SHOULD summarize warnings with source file paths and request explicit resolution/acceptance before any Docker build.

5. Universal failure-redirection protocol

Mandatory response sequence for every failed gate

1. HALT the current phase and every dependent write. State clearly that no dependent AWS change or deletion was attempted.
2. IDENTIFY the gate ID, failing command/check, selected account/profile/Region/project/environment (redacted when sensitive), and the first relevant ERROR - not the final cascade.
3. EXPLAIN why the criterion protects cost, security, ownership, recoverability, data, or cancellation behavior.
4. REDIRECT with exact safe actions. Prefer a read-only verification command and a named repository guide. Never request raw credentials or secret-bearing files.
5. PROHIBIT the tempting unsafe shortcut: no sudo for AWS root, no guessed account ID, no --run-as-root convenience, no edited DynamoDB, no deleted lock, no random console deletion, no hidden --yes, no credential pasted into chat.
6. PRESERVE the retained error-log path and any review-only inventory/manifest. Redact phone/email/message/state-secret values from summaries.
7. RESUME at the exact failed gate. If configuration, source, plan, identity, backend, channel, or deadline changed, rebuild all downstream plan/artifacts and request approvals again.

Required operator-facing shape

```
BLOCKED AT <GATE-ID>: <plain-language criterion>

No dependent AWS write/deletion was attempted.
Evidence: <first safe error and retained log path>
Why this blocks: <risk being prevented>

Do this:
1. <exact remediation>
2. <read-only verification command>
3. <exact retry command/gate>

Do not: <specific unsafe bypass>
```

CAUTION: Do not solve uncertainty with authority escalation

When the account, state owner, deletion scope, credential, deadline, channel, cost, or application data model is unclear, ask the responsible human to decide. --run-as-root, broader IAM, public CIDRs, console deletion, and guessed defaults are not clarification tools.

6. Prerequisite gate routing matrix

Each row is a normative stop-and-redirect rule. The agent **MUST** use the named retry point and **MUST** regenerate dependent artifacts after a material change.

Gate	Detection	Mandatory redirect	Retry
G01 Wrong repository/path	Git remote/top-level or destination path does not match operator scope; sources/ or unrelated workspace selected.	Stop. Show resolved path, remote, branch, status. Ask owner to select correct clone/path. Treat sources/ as read-only.	Discovery
G02 Existing changes collide	Dirty/untracked user work overlaps files to be replaced or packaged.	Stop writes. Preserve changes. Show file-level overlap and ask owner to resolve/approve a specific merge strategy. Never reset/checkout/delete.	Discovery
G03 Missing program	validate/preflight reports AWS CLI, Terraform, Python, jq, curl, or required Docker absent.	Direct to docs/WORKSTATION_SETUP.md/vendor install. Reopen shell; print version. Do not silently install with privilege.	Local validate
G04 Validation/provider failure	Syntax/tests/format/package allowlist/secret scan/provider init/schema fails.	Fix source or supported runtime. If provider cannot execute in sandbox, validate on normal workstation/CI and retain limitation. Do not claim success from fmt alone.	Local validate
G05 App contract failure	inspect_app blocks or port/health/state/log/security decision unproven.	Correct app/Docker context; explain exact APP ID; rerun inspect and human review. Never publish first and debug in AWS.	App qualify
G06 First-run caller not AWS root	STS ARN does not end in :root for initial service-account bootstrap.	Stop. Instruct authorized account owner to use temporary aws login profile and MFA. Do not use sudo or request a root access key.	First identity
G07 Normal caller is AWS root	Any routine AWS-facing helper sees :root without an explicit owner-approved exception.	End root session; select saved service/approved role profile; prove STS. Do not recommend --run-as-root as a convenience.	Preflight
G08 Auth absent/expired	STS cannot identify caller or browser/SSO session expired.	Use aws login or aws sso login under approved local profile; verify STS. Never solicit/paste raw keys or tokens.	Identity/preflight
G09 Wrong account/Region	STS Account differs from written approval; Region disabled/unreadable; SNS/backend account/Region mismatch.	Stop. Show safe identifiers, select correct profile/Region, rerun STS/preflight. Familiar-looking is not sufficient.	Identity/preflight
G10 First run partial/existing	Marker exists, rollback incomplete, or user/policy/key/profile shape ambiguous.	Audit retained error, tagged IAM objects, CloudTrail, local profiles, key status. Reconcile with owner before rerun. Never delete marker to silence check.	First identity
G11 IAM proof fails	Strict preflight or SimulatePrincipalPolicy incomplete/denied; organization control/quota suspected.	Send exact failed actions to AWS admin; review docs/PERMISSIONS.md, SCP/boundary/Region/quota. Do not broaden to AdministratorAccess by default.	Preflight
G12 Settings invalid/missing	No real tfvars, invalid names/CIDRs/count ordering/retention/email/image/health configuration.	Copy example locally, obtain owner decisions, correct validation errors. Keep real file ignored. Rerun validate/plan.	Configure
G13 Backend unproven	backend.hcl absent/ambiguous, deterministic bucket/key/Region mismatch, S3 access denied, or lock active.	Run guarded bootstrap if new. Otherwise prove owner/account/key. Coordinate lock release; never delete lock blindly or move state as source.	Configure/init
G14 Cost approval absent	No current estimate/owner, budget email unmonitored, Free Tier assumption, or exact phrase refused.	Present not-free warning and estimate assumptions; assign cost owner; verify current pricing/alerts. Do not apply or fabricate acceptance.	Plan/apply
G15 Plan unexpected/stale	Wrong account/resource/action; unreviewed create/update/delete; source/hash/input changed after planning.	Stop. Correct cause, rebuild fresh saved plan/artifacts, review all actions, request approval again. Never apply stale plan.	Plan
G16 Schedule deadline invalid	Initial deadline <13h; later plan/apply <12h15; ambiguous/nonexistent local time; timezone unproven.	Choose a new valid duration/local minute, confirm displayed local+UTC, regenerate configuration and plan. Do not edit epoch manually.	Schedule configure

Gate	Detection	Mandatory redirect	Retry
G17 SMS path ineligible	Number not account-owned ACTIVE US TOLL_FREE SMS two-way carrier-opt-out, topic mismatch, dry-run denied, sandbox/registration issue.	Have owner provision/fix eligible number/topic in same account/Region; rerun no-send validator. Do not purchase automatically or use personal cell as originator.	Schedule channels
G18 Email not timely	SNS subscription remains PENDING or confirmation detected with <=12h remaining.	Confirm if time remains. If late, fail closed; create a new reviewed schedule/manual destroy. Never edit DynamoDB to force ACTIVE.	Post-apply schedule
G19 Cancellation invalid/late	Reply not exact CANCEL, wrong source/destination, email reply, STOP, or state EXECUTING.	Read schedule-status. Explain exact SMS rule. CANCELLED is authoritative; EXECUTING cannot roll back. Do not claim email/STOP cancels.	Schedule status
G20 Inventory incomplete	Any account inventory read fails or coverage limitation hides confidence.	Block deletion; preserve report; fix permission/network/Region and rerun review. Never interpret incomplete/empty as nothing exists.	Self-destruct review
G21 Ownership proof fails	Backend/user names, tags, versioning, Object Lock, MFA Delete, credential shape, caller separation, or account mismatch.	Keep protected assets. Resolve ownership with owner/admin and rerun review. No manual mass deletion or guessed override.	Self-destruct review
G22 Destroy plan unsafe	Plan contains create/update, unexpected empty deletion, or wrong scope.	Refuse execution. Correct drift/source/state, regenerate deletion-only saved plan, re-review. Never edit JSON plan to pass gate.	Destroy plan
G23 Partial teardown	Terraform/CodeBuild deletion stops; managed runtime remains.	Keep backend and identity. Read first 90-day error, fix dependency/permission, rerun dependency-ordered process, inventory afterward. No random console deletes.	Destroy recovery
G24 Git authority absent	Operator asks for docs/code but not commit/push/PR/merge, or standing review-first instruction applies.	Leave changes local. Present file list, validation, proposed commit title/body. Wait for explicit source-control instruction.	Handoff

7. Creation implementation procedure

Exact operator sequence

```
# 1. Local only
./scripts/workspace.sh validate
./scripts/inspect_app.sh /absolute/path/to/application --json

# 2. One-time AWS root bootstrap
aws login --profile aws-root-bootstrap
aws sts get-caller-identity --profile aws-root-bootstrap
./scripts/first_run_setup.sh --root-profile aws-root-bootstrap --region us-west-2
aws logout --profile aws-root-bootstrap

# 3. Normal service identity and environment configuration
cp terraform/terraform.tfvars.example terraform/terraform.tfvars
./scripts/bootstrap_backend.sh --region us-west-2 --project PROJECT --environment ENV
./scripts/workspace.sh preflight --region us-west-2
./scripts/workspace.sh init --region us-west-2

# 4. Review and create
./scripts/workspace.sh plan --region us-west-2
./scripts/workspace.sh apply --region us-west-2
./scripts/workspace.sh status --region us-west-2
```

Implementation invariants

- All commands run from the attached kit top-level directory. Placeholder values are replaced explicitly; do not type angle/square brackets.
- `first_run_setup` writes the access key directly to the shared credentials file with restrictive permissions, never stdout/arguments/logs. Terraform MUST NOT create that access key because it would land in state and cannot switch its active provider identity mid-run.
- Normal helpers resolve an explicit `--profile` first, otherwise the ignored saved service profile. Every AWS-facing path checks STS and blocks root unless a deliberate one-command exception was authorized.
- Apply MUST create a fresh saved plan, show cost warning, and require I ACCEPT ESTIMATED AWS CHARGES. A generic `--yes` is prohibited.
- Plan/apply MUST use the same approved account, Region, backend, variables, and source. Changed inputs invalidate the prior approval.
- The initial deployment may use the public nginx smoke image. Publishing the parent app is a second inspected, confirmed, digest-pinned plan/apply cycle.

Post-apply proof

- Terraform outputs are readable; status identifies load balancer URL and instance(s).
- Health checks pass; application route responds only with non-sensitive smoke data.
- Budget notification emails are confirmed and AWS native Free Tier alerts enabled.
- Routine/error log groups and retention are correct; no secret/PII content observed.
- Named owner, intended destroy time, and next review are recorded.

8. Scheduled teardown implementation

CAUTION: Notification is best-effort, state is authoritative

Carrier/email delay, filtering, service outage, quota, account suspension, or policy change can prevent notices or teardown. Automation reduces forgotten resources; it is not a guarantee. Keep cost budgets and a human owner.

Local configuration and channel gates

- First plan/apply prompts only when ignored scheduled configuration is absent. Accept duration or local YYYY-MM-DD HH:MM, detect an IANA timezone, display local and UTC, and reject DST ambiguity/nonexistence.
- Initial deadline MUST be ≥ 13 h away. Every later plan/apply MUST block when < 12 h15 remains.
- Require operator cell/email plus account-owned ACTIVE U.S. TOLL_FREE two-way AWS originator and exact inbound SNS topic. Validate same account/Region and SendTextMessage --dry-run with no delivery.
- Do not auto-procure/register a number. The account owner controls business identity, campaign, country, registration, recurring cost, and consent.
- The U.S. toll-free/carrier-opt-out restriction preserves CANCEL for application routing; STOP is the carrier opt-out and does not cancel teardown.

State machine

From	Event / guard	To	Required behavior
PENDING	Email confirmed while > 12 h remains	ACTIVE	Send ARMED SMS/email; begin milestone enforcement.
PENDING	No/late confirmation	PENDING	Fail closed; never start deletion.
ACTIVE	Milestone due	ACTIVE	Attempt 12h/2h/1h/15m/5m SMS+email; mark only completed milestones; retry failures.
ACTIVE/TRIGGERING /TRIGGERED	Exact CANCEL; enrolled source and destination; before execution claim	CANCELLED	Atomic state win; attempt acknowledgements; state is authoritative.
ACTIVE	Deadline reached	TRIGGERING	Atomic transition; idempotently start CodeBuild.
TRIGGERING	Build start succeeds	TRIGGERED	Record build identity. Build still must pass final gate.
TRIGGERING	Build start fails	ACTIVE	Return to retryable state.
TRIGGERED	Build proves account/state and deletion-only plan	EXECUTING	Atomic claim immediately before exact saved plan apply.
EXECUTING	Late CANCEL	EXECUTING	Reject; deletion is irreversible. Redeploy is recovery.

Deletion-build safety gates

1. Prove the expected 12-digit AWS account.
2. Require authoritative DynamoDB state TRIGGERED.
3. Download Terraform 1.15.8 and verify the HashiCorp checksum file.
4. Reconstruct the exact S3 backend bucket/key/Region from reviewed source/configuration.
5. Create a saved terraform plan -destroy. Reject unexpected empty teardown and any create/update action.
6. Atomically claim EXECUTING. If cancellation/other state won, exit; otherwise apply only the exact saved deletion plan. Runtime/control self-delete; protected backend/identity remain.

9. Manual destruction implementation

Routine runtime removal

```
./scripts/workspace.sh destroy --region us-west-2
```

- Generate/display a fresh destroy plan and require DESTROY AWS WORKSPACE.
- Do not remove the protected backend or bootstrap identity.
- On partial failure, preserve state/identity, fix first error, rerun Terraform in dependency order, and inventory afterward.

Full project retirement

```
# Phase 1 - no deletion
./scripts/self_destruct.sh --review-only --profile cleanup-admin --region us-west-2 --project PROJECT \
  --environment ENV

# Phase 2 - only after independent review and explicit scope approval
./scripts/self_destruct.sh --execute --expected-account 123456789012 --profile cleanup-admin --region \
  us-west-2 --project PROJECT --environment ENV
```

Full-retirement invariants

- Review-only is default and MUST run first. Preserve the broad inventory and narrow deletion manifest. Any incomplete AWS read blocks execute.
- Runtime ownership comes from exact backend coordinates, readable state, account, Region, project/environment, and a saved plan containing only delete/read/no-op.
- --delete-state-bucket additionally requires deterministic name, owner, exact bootstrap tags, versioning enabled, and Object Lock/MFA Delete absent. Delete every version/marker in bounded checked batches.
- --delete-service-account additionally requires a working local service profile that resolves to the exact tagged bootstrap user/credential shape, no unexpected login/MFA/group/cert/key/policy objects, and a different cleanup identity with proved deletion permission (or explicit root exception).
- Execute phrase MUST be SELF DESTRUCT ACCOUNT PROJECT ENVIRONMENT. Do not expose a general noninteractive bypass. If runtime remains, keep state and identity for recovery.
- Post-destroy: confirm state has no managed runtime, search tags/services for leftovers, verify budgets removed/independent account budget retained, and review Billing next day.

10. Logging, retention, secrets, and evidence

Evidence class	Retention	AI handling
Local success	14 days / 20 files	Summarize outcome and path; do not paste entire logs unnecessarily.
Local errors	90 days / 100 files	Use first ERROR, preserve path, redact secrets/PII, prefer exact safe lines.
Local inventory/manifests	365 days / 20 files	Broad inventory is review evidence only, never delete authorization.
CloudWatch routine	Normally 14 days	Check health/bootstrap/app streams; do not increase without cost approval.
CloudWatch error/schedule	90 days	Use controller/build state and first failure; logs intentionally omit contact/message bodies.
ALB request logs	Normally 30 days	Treat URLs/metadata as potentially sensitive; export only under approved retention.
Backend versions	Protected versioned S3; noncurrent lifecycle documented at 365 days	State can contain contact values; never send to model or package.

Redaction rules

- Never echo access-key IDs with secrets, secret keys, session tokens, passwords, private keys, MFA codes, authorization headers, cookies, .env contents, or Terraform state.
- Phone/email values are collected locally by the schedule configurator. An AI may say enrolled phone/email without reproducing the value. Do not quote inbound SMS payloads/message bodies.
- Account IDs are necessary for ownership confirmation and may be displayed to the authorized operator, but never guess them. Do not treat a partial/masked ID as sufficient for destructive confirmation.
- Do not disable logging to hide an error. Rotate by documented age/count, retaining failures longer than successes.

Cost evidence

- Present the repository's approximately US\$1.40/day default estimate as an assumption-bound estimate, never a quote or Free Tier promise.
- Present schedule costs separately: number rental/registration/campaign, at least six outbound messages, minute scheduler, Lambda/DynamoDB/SNS/CloudWatch/S3, and one CodeBuild teardown.
- Budgets at ~US\$0.01, US\$1, and US\$5 are account-wide gross actual/forecast notifications. They are delayed alarms, not circuit breakers.
- Use current official AWS pricing and account Free Tier/Billing data immediately before a real apply. Assign a human cost owner.

11. Validation and acceptance criteria

Minimum technical validation

```
./scripts/workspace.sh validate
./scripts/inspect_app.sh /absolute/path/to/application --json
./scripts/workspace.sh preflight --region REGION
./scripts/workspace.sh plan --region REGION
```

Area	Acceptance evidence
Local source	Bash syntax, Python compile/tests, Terraform fmt/structure/provider validation in a supported runtime, package allowlist/checksum, secret-pattern and whitespace checks pass.
Application	APP-01 through APP-08 pass or warnings have explicit owner disposition; Docker build context reviewed.
Identity	Correct account; root only at first bootstrap; normal ARN is dedicated user/approved role; strict permission proof passes.
Backend	Exact deterministic bucket/key/Region; encrypted/versioned; readable; no uncoordinated lock.
Plan	Fresh saved proposal matches change statement; no unexpected deletion/replacement/public exposure/capacity/IAM/schedule change.
Cost	Current estimate assumptions, budget recipients/confirmation, native Free Tier alerts, maximum capacity, and schedule costs approved.
Apply	Authorized human enters exact phrase; exact plan applies; outputs/status/health/logs verified.
Schedule	Eligible two-way channel/no-send dry-run; valid deadline; timely email; ACTIVE/ARMED observed; CANCEL behavior explained/tested without unsafe live deletion.
Destroy	Review-only evidence; deletion-only plan; exact confirmation; retained assets and next-day Billing check documented.

Sandbox/runtime limitation handling

If Terraform providers download successfully but cannot complete the provider plugin handshake in a managed sandbox, report the failure accurately. Do not label Terraform validation successful based only on fmt or init. Route G04: repeat terraform validate in a supported normal workstation or CI runner with matching architecture/network, retain the exact provider/runtime error, and keep apply blocked until that proof passes.

No live side effects during documentation/test-only work

- A documentation request authorizes reading/generating docs, not AWS creation, SMS/email delivery, IAM changes, Git commit/push, PR creation, merge, or deletion.
- Use dry-run/read-only commands where supported. Explicitly state when no live AWS resources or messages were created.

12. Operator response templates

Missing or expired credentials

```
BLOCKED AT G08: AWS could not identify the approved caller.  
No AWS resource was changed.  
  
Use the organization's approved browser/SSO login for a named local profile,  
then run:  
    aws sts get-caller-identity --profile PROFILE  
  
The Account must equal the approved 12-digit ID and the normal-use ARN must  
not end in :root. Do not paste an access key, secret, token, or MFA code here.  
Retry: ./scripts/workspace.sh preflight --profile PROFILE --region REGION
```

Wrong identity for first run

```
BLOCKED AT G06: first-run bootstrap requires verified AWS account root.  
This means an STS ARN ending in :root; it does not mean sudo or OS root.  
  
Have the authorized account owner use temporary `aws login` credentials with  
MFA in a clearly named profile, verify the exact account ID, then rerun  
first_run_setup.sh. Never create or request a permanent AWS root access key.
```

Normal operation accidentally using root

```
BLOCKED AT G07: normal operation detected AWS account root.  
No Terraform action was attempted.  
  
End the root browser session, use the saved service profile or approved role,  
and verify with STS/preflight. Do not add --run-as-root merely to bypass this  
failsafe; that flag requires explicit owner approval for one exceptional call.
```

Cost approval missing

```
BLOCKED AT G14: billable infrastructure has no current owner approval.  
No apply was attempted.  
  
Review the fresh plan, current AWS prices/Free Tier status, repository estimate,  
maximum instance count, log retention, budget recipients, and optional SMS costs.  
An authorized human must decide whether to enter the exact apply phrase. I will  
not fabricate or prefill that approval.
```

Destruction scope unproven

```
BLOCKED AT G20/G21/G22: deletion scope or ownership is not fully proven.  
No deletion was attempted.  
  
Preserve the backend, service identity, review inventory, deletion manifest,  
and error log. Correct the first failed account/Region/backend/tag/permission/  
plan check and rerun review-only mode. Do not delete random console resources,  
edit the plan JSON, or treat broad inventory as deletion authority.
```

13. Machine-readable execution contract

The following YAML-like block is intentionally redundant with the normative prose so an AI can extract a compact policy. The prose and repository code win if a field is ambiguous.

```

artifact: AWS-EnvBuilder
contract_version: "1.0"
baseline_commit: "341f6fe"
default_region_example: "us-west-2"

authority:
  documentation_only_creates_aws: false
  auto_commit_or_push: false
  request_raw_credentials: false
  generic_yes_flag_allowed: false

identity:
  first_run_required_principal: "arn ending :root"
  first_run_is_os_root: false
  normal_root_allowed: false
  root_exception: "explicit --run-as-root for one owner-approved command"
  preferred_enterprise_identity: "short-lived role or IAM Identity Center"

gates:
  local_validate: required
  app_inspection: required
  exact_account_and_region: required
  strict_permission_simulation: required_for_plan_apply
  protected_backend: required
  fresh_plan: required
  cost_approval_phrase: "I ACCEPT ESTIMATED AWS CHARGES"
  routine_destroy_phrase: "DESTROY AWS WORKSPACE"
  full_destroy_phrase: "SELF DESTRUCT <ACCOUNT> <PROJECT> <ENV>"

schedule:
  optional: true
  initial_minimum_hours: 13
  replan_block_remaining: "12h15m"
  notices: ["ARMED", "12h", "2h", "1h", "15m", "5m"]
  cancel_channel: "SMS only"
  cancel_body: "CANCEL"
  stop_is_cancel: false
  email_reply_is_cancel: false
  cancellation_cutoff: "before atomic EXECUTING claim"
  retained_after_destroy: ["protected state backend", "bootstrap identity"]

failure_protocol:
  - halt_dependent_actions
  - identify_gate_and_first_error
  - explain_risk
  - give_exact_safe_remediation_and_read_only_verification
  - name_prohibited_bypass
  - preserve_redacted_log_path
  - resume_at_failed_gate_and_rebuild_downstream_artifacts

```


AI completion report fields

```
Outcome: <complete | blocked | review-ready>
Repository/path: <absolute path and branch>
Builder baseline: <release/checksum/commit>
AWS side effects: <none | exact approved actions>
Identity evidence: <safe ARN class, account, Region>
Application evidence: <inspection outcome, port, health, stateless decision>
Cost evidence: <estimate date/assumptions and owner approval state>
Plan evidence: <saved plan and intended create/update/delete summary>
Schedule evidence: <disabled | deadline/state/channel proof, contacts redacted>
Validation: <commands and results; limitations named>
Files changed: <exact list>
Git actions: <none unless explicitly requested>
Next operator action: <single exact safe step>
```

14. Repository map and official references

NOTE: Source-of-truth order

Use the checked-out repository code and its Markdown guides first, then current official AWS documentation/pricing, then this PDF. If implementation and PDF differ, stop, report the exact difference, and ask the owner to review the newer code before proceeding.

Implementation file map

Path	Responsibility
README.md	Canonical operator syntax and full safe path.
scripts/workspace.sh	Main validate/preflight/init/plan/apply/status/logs/schedule-status/destroy dispatcher.
scripts/lib/common.sh	Identity selection/root guard, exact confirmation, output/logging/retention helpers.
scripts/preflight.sh + permissions.sh	Tool/auth/Region/current-CLI and IAM action simulation.
scripts/first_run_setup.sh	One-time root-to-service-user bootstrap, protected credential write, rollback.
scripts/bootstrap_backend.sh	Guarded deterministic encrypted/versioned S3 state backend.
scripts/inspect_app.py/.sh	Read-only manifests/Docker/secret-pattern application gate.
scripts/publish_app.sh	Confirmed build/push, digest resolution, ignored Terraform app variable.
scripts/configure_scheduled_destroy.py	Duration/local-time input, timezone/UTC, consent, ignored schedule variable.
scripts/validate_scheduled_destroy_channels.sh	Account/Region/number/topic/two-way/opt-out and no-send SMS checks.
scripts/scheduled_destroy_controller.py	PENDING/ACTIVE/notices/CANCEL/deadline trigger state machine.
scripts/scheduled_destroy_build.py	Expected state, deletion-only plan, atomic execution claim.
scripts/self_destruct.sh + account_inventory.py	Broad read inventory, narrow ownership proof, review/execute permanent scopes.
scripts/package.sh	Allowlisted source archive and checksum; excludes runtime/sensitive artifacts.
terraform/*.tf	Runtime, costs, logs, security, registry, budget, and optional schedule declarations/checks.
tests/	Identity, application, schedule, and self-destruct offline regression tests.
docs/*.md	Human source of truth for architecture, setup, permissions, costs, app, schedule, teardown, troubleshooting.

Official references

AWS CLI browser login https://docs.aws.amazon.com/cli/latest/userguide/cli-configure-sign-in.html	IAM access-key security https://docs.aws.amazon.com/IAM/latest/UserGuide/securing_access-keys.html
IAM roles https://docs.aws.amazon.com/IAM/latest/UserGuide/id_roles.html	AWS Free Tier alerts https://docs.aws.amazon.com/awsaccountbilling/latest/aboutv2/tracking-free-tier-usage.html
Request SMS number https://docs.aws.amazon.com/sms-voice/latest/userguide/phone-numbers-request.html	Two-way SMS https://docs.aws.amazon.com/sms-voice/latest/userguide/two-way-sms.html
SMS opt-out keywords https://docs.aws.amazon.com/sms-voice/latest/userguide/keywords-required.html	End User Messaging pricing https://aws.amazon.com/end-user-messaging/pricing/
EventBridge pricing https://aws.amazon.com/eventbridge/pricing/	CodeBuild pricing https://aws.amazon.com/codebuild/pricing/
S3 version deletion https://docs.aws.amazon.com/AmazonS3/latest/userguide/DeletingObjectVersions.html	IAM user removal https://docs.aws.amazon.com/IAM/latest/UserGuide/id_users_remove.html